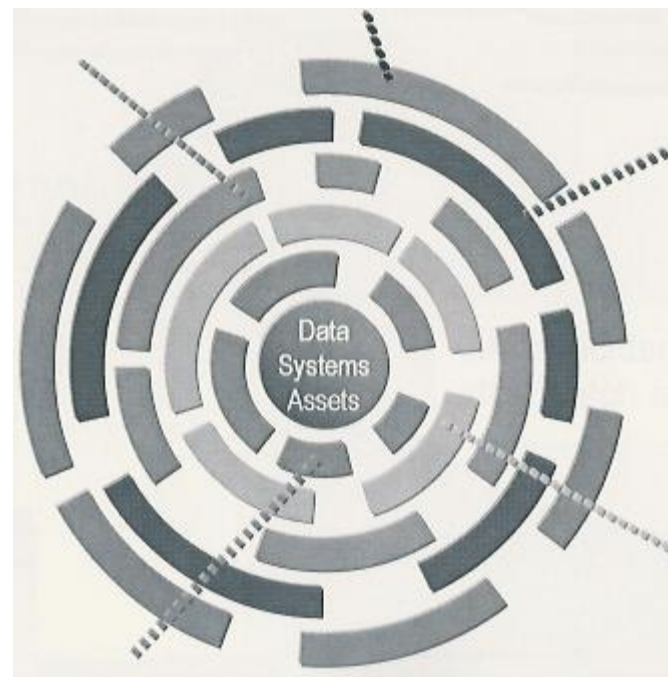


2. Sisteme pentru Detectarea / Prevenirea Intruziunilor (IDS/IPS)



Necesitatea utilizării unui IDS

- Cea de-a doua linie de apărare după firewall
 - principiul apărării în adâncime (*defence in depth*)
 - o serie de atacuri nu pot fi stopate de către firewall (CodeRed, Nimda, etc)



Necesitatea utilizării unui IDS (cont.)

- **Detectează atacuri ce nu pot fi prevenite de către celelalte mecanisme de securitate**
- **Oferă o imagine asupra atacurilor la care este supusă în mod curent o organizație**
- **Instrument de măsură a eficienței mecanismelor de securitate implementate**
- **Furnizează dovezile necesare pentru tragerea la răspundere a atacatorilor**

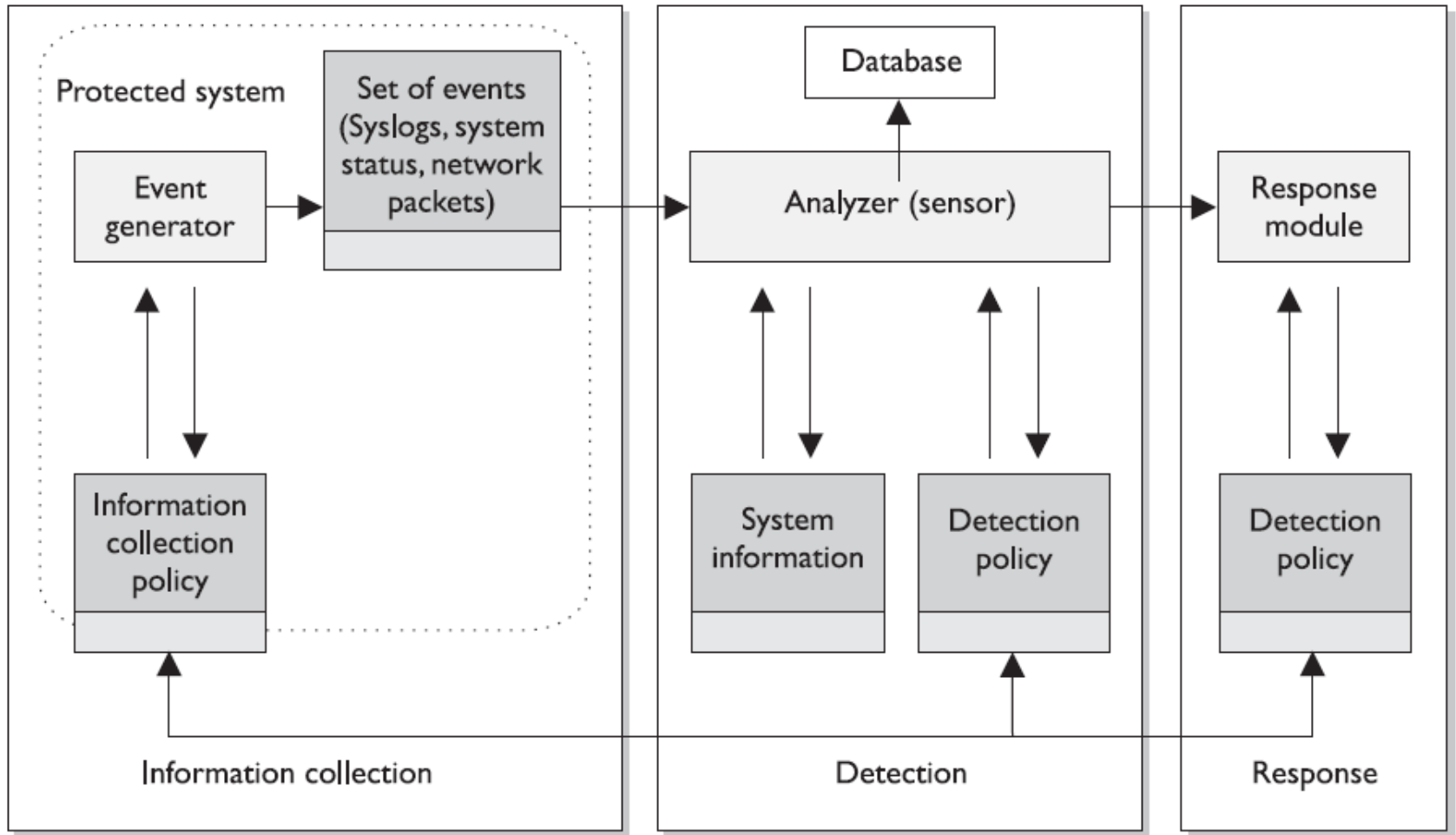
Definiții

- ***Intruziune***
 - set de acțiuni având ca obiectiv compromiterea securității unui calculator
- ***Detectarea intruziunilor (intrusion detection)***
 - procesul de identificare și combatere a intruziunilor
- ***Sisteme pentru detectarea intruziunilor (IDS)***
 - unelte și metode ce ajută la identificarea, evaluarea și raportarea intruziunilor
 - echivalent cu sistemele de securitate fizică: camere de supraveghere, senzori de mișcare, etc
- ***Sisteme pentru prevenirea intruziunilor (IPS)***
 - IDS cu capabilități de stopare a intruziunilor

Terminologie

- fals pozitiv (*false positive*)
 - activitățile normale sunt considerate atacuri
- fals negativ (*false negative*)
 - activitățile malițioase nu sunt detectate
- atac de tip “*low and slow*”
- atac / virus “*in the wild*”
- atac / virus “*in the zoo*”

Arhitectura unui IDS



Tipuri de IDS

- **Funcție de modul de colectare a evenimentelor**
 - IDS la nivel rețea (*NIDS - Network-based IDS*)
 - IDS la nivel host (*HIDS - Host-based IDS*)
- **Funcție de mecanismul de detecție folosit**
 - IDS bazat pe semnături (*signature-based detection*)
 - IDS bazat pe anomalii (*anomaly-based detection*)
- **Funcție de modul de răspuns la intruziuni**
 - IDS pasiv
 - IDS activ

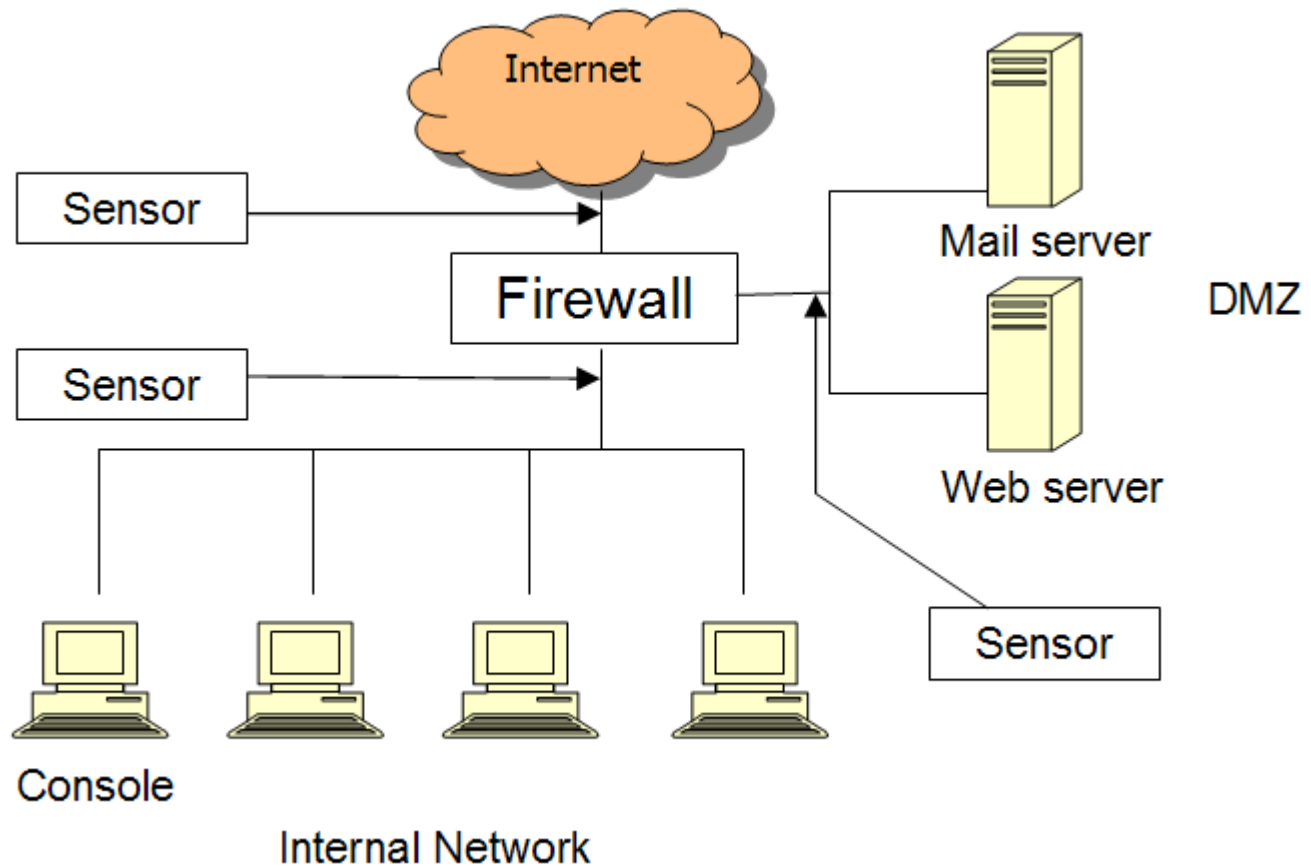
IDS la nivel rețea

- **Monitorizarea traficului din rețea**
 - captare și analiză pachete
- **Senzori cu interfețe de rețea ce operează în *promiscuous mode***
- **Tehnici de captare a traficului de rețea**
 - SPAN Port
 - TAP
 - Network Packet Broker
- **Permit detecția atacurilor de scanare de porturi, DoS, propagare malware sau încercări de acces neautorizat**

IDS la nivel rețea (cont.)

- **Avantaje:**
 - scalabilitate ridicată (cu câțiva senzori bine plasați se poate monitoriza o rețea întreagă)
 - nu afectează performanțele sistemelor monitorizate
 - poate opera astfel încât să fie invizibil pentru atacatori (*stealth mode*)
- **Dezavantaje:**
 - nu protejează sistemele împotriva utilizatorilor interni
 - pot rata pachete în cazul unui volum mare de trafic (~Gbps)
 - folosirea mai multor senzori în paralel
 - implementarea hardware a funcțiilor critice (appliances)
 - nu poate analiza traficul criptat (VPN)
 - poate identifica doar faptul că un atac a fost inițiat nu și dacă a avut succes

IDS la nivel rețea (cont.)



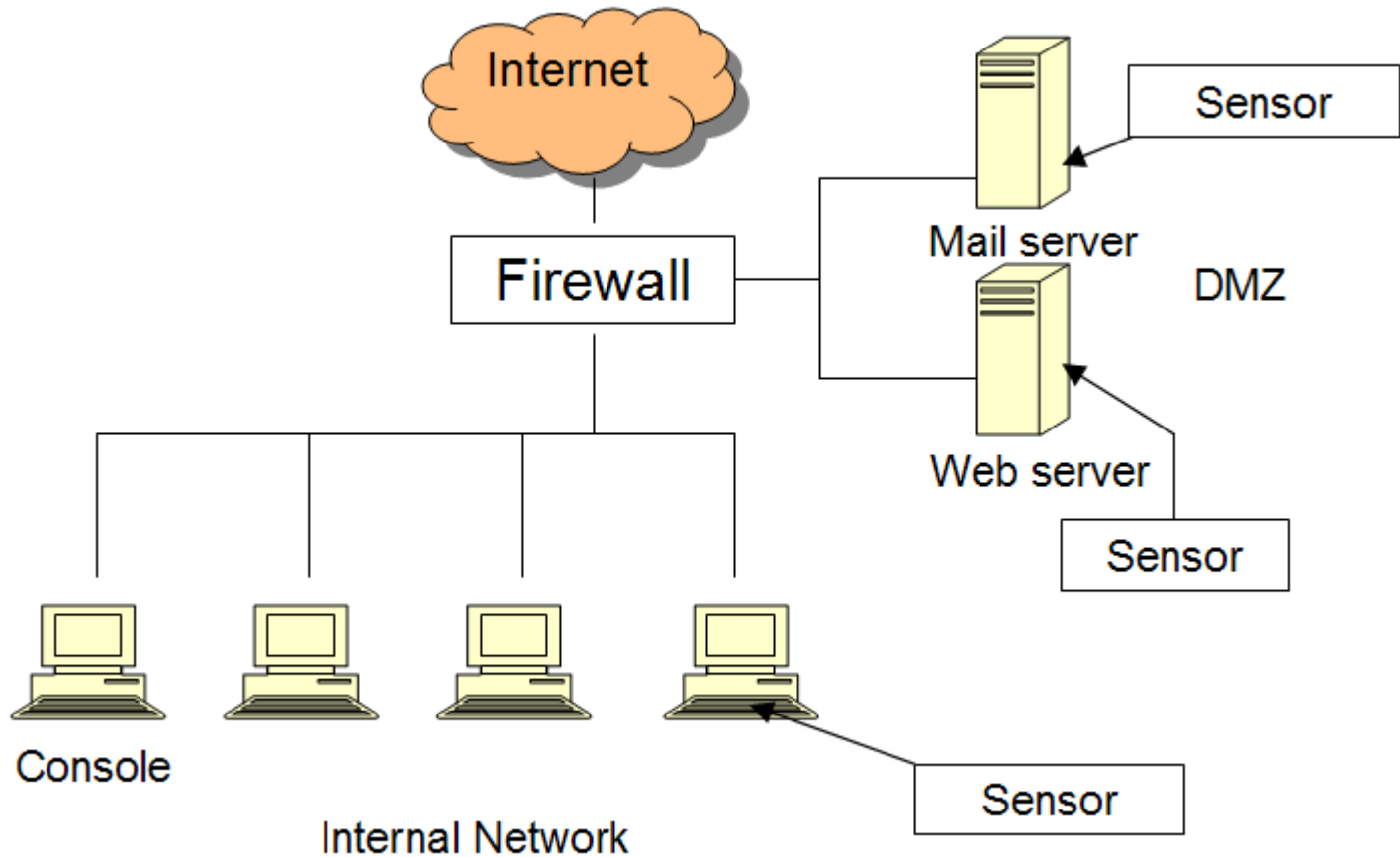
IDS la nivel host

- **Monitorizarea evenimentelor din cadrul unui sistem de calcul**
 - analiza log-uri, procese active
- **Verificarea integrității fișierelor**
 - sume de control criptografice ce sunt calculate periodic și comparate cu valorile de referință
 - Tripwire, AIDE, Afick
- **Permite detectarea atacurilor precum și evaluarea pagubelor produse de acestea**

IDS la nivel host (cont.)

- **Avantaje:**
 - nu necesită echipamente suplimentare – se instalează pe sistemele monitorizate
 - pot detecta atacuri ce nu pot fi văzute de către un NIDS (ex. trojan horse)
 - funcționează și în cazul criptării traficului
- **Dezavantaje:**
 - scalabilitate redusă
 - afectează performanța sistemelor monitorizate
 - odată compromis sistemul, IDS-ul poate fi dezactivat
 - nu poate detecta atacuri de scanare a rețelei, DoS, etc

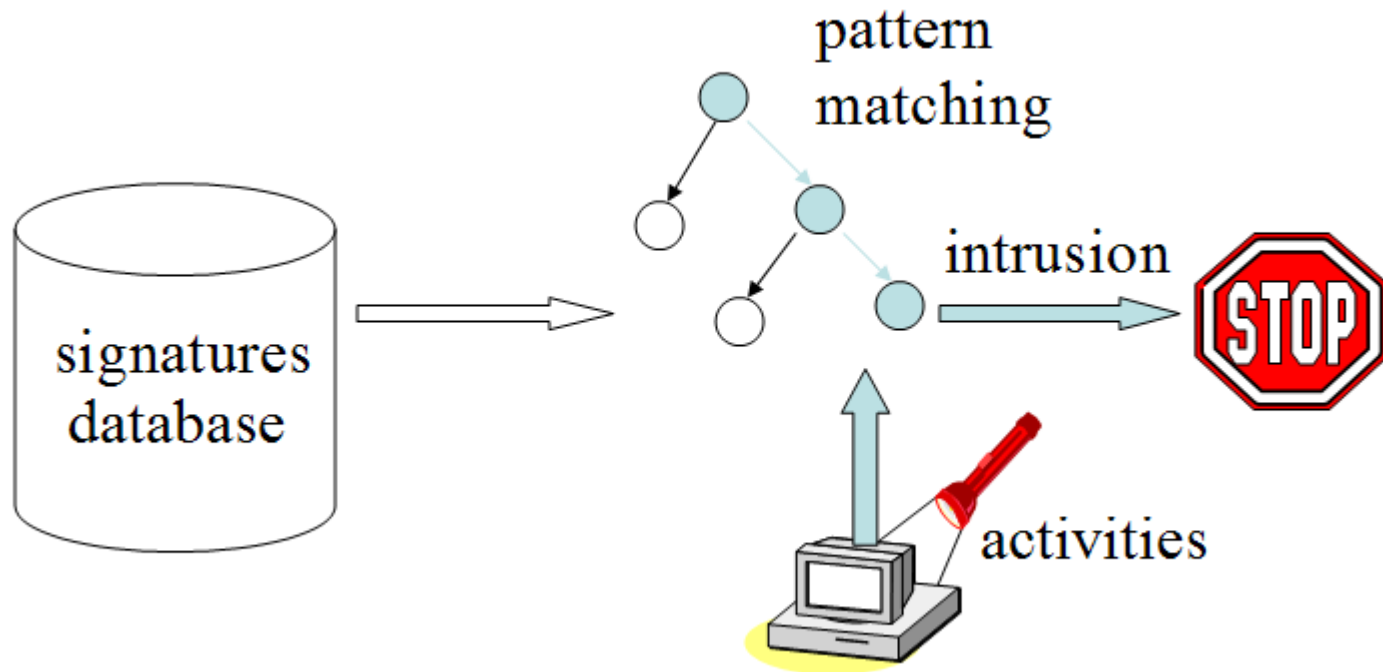
IDS la nivel host (cont.)



IDS bazat pe semnături

- Similar sistemelor antivirus
- Fiecare atac cunoscut până în momentul de față are o semnătură
 - secvență specifică de octeți în cadrul pachetelor de rețea
 - pattern în cadrul fișierelor de log
 - valoare hash pentru fișierele malițioase
- IDS dispune de o bază de date de semnături ce trebuie actualizată periodic
- Presupune acumularea de cunoștințe despre fiecare atac în parte pentru construirea semnăturii
 - knowledge based IDS
- Cel mai răspândit tip de IDS

IDS bazat pe semnături (cont.)



IDS bazat pe semnături (cont.)

- **Avantaje:**

- eficiența sistemului depinde modul în care este actualizată baza de date de semnături
- număr relativ scăzut de alarme de tip *false positive*
- oferă informații detaliate despre tipul de atac

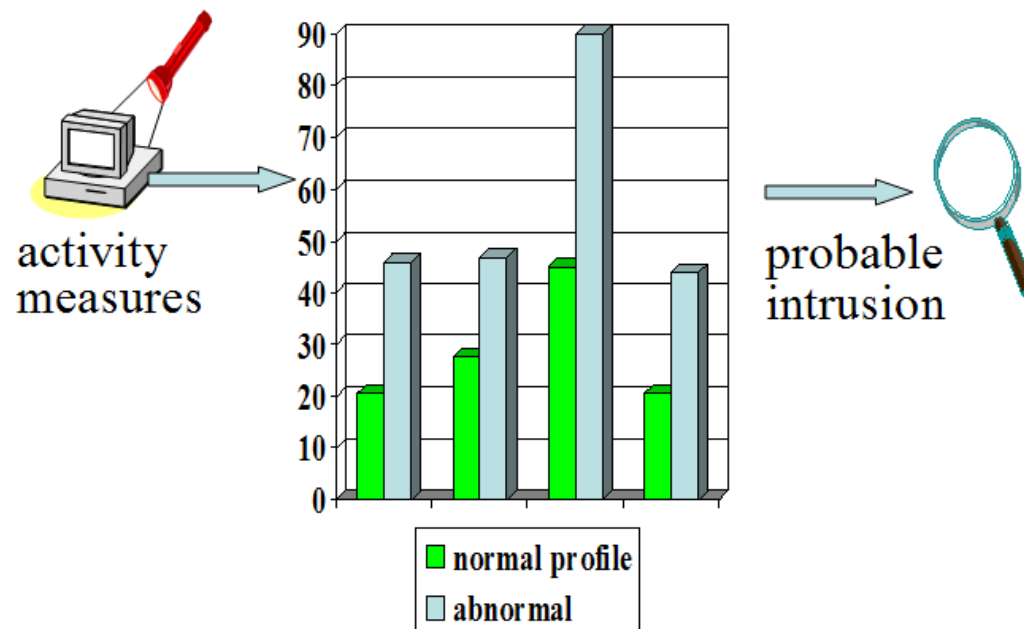
- **Dezavantaje:**

- nu poate detecta noi tipuri de atacuri
- cu cât baza de date de semnături este mai mare cu atât sistemul este mai lent (implementări hardware)

IDS bazat pe anomalii

- **Anomalie = deviere de la starea normală**
- ***Learning mode* – construirea unui profil al stării normale a sistemului**
 - acuratețea profilului depinde de durata procesului de învățare
 - pe durata procesului de învățare, nu trebuie să existe atacuri în sistem
- ***Detection mode* – compararea stării curente cu cea prestabilită**
 - o deviere mare față de starea normală este interpretată drept un posibil atac ce trebuie investigat
- ***Analiză statistică* – identificarea deviațiilor (anomaliilor)**
 - calcularea abaterii standard
 - folosirea de algoritmi de învățare automată (machine learning)

IDS bazat pe anomalii (cont.)



IDS bazat pe anomalii (cont.)

- **Network Behavior Anomaly Detection (NBAD)**
 - monitorizarea traficului pentru vedea cine cu cine dialoghează
 - analiza modului de derulare a protocoalelor de rețea (formatul pachetelor, ordinea în care acestea sunt transmise, etc)
 - consumul de resurse (lățime de bandă, încărcarea procesoarelor, etc)
- **User Entity Behavior Analytics (UEBA)**
 - analiza activității utilizatorilor (login patterns)

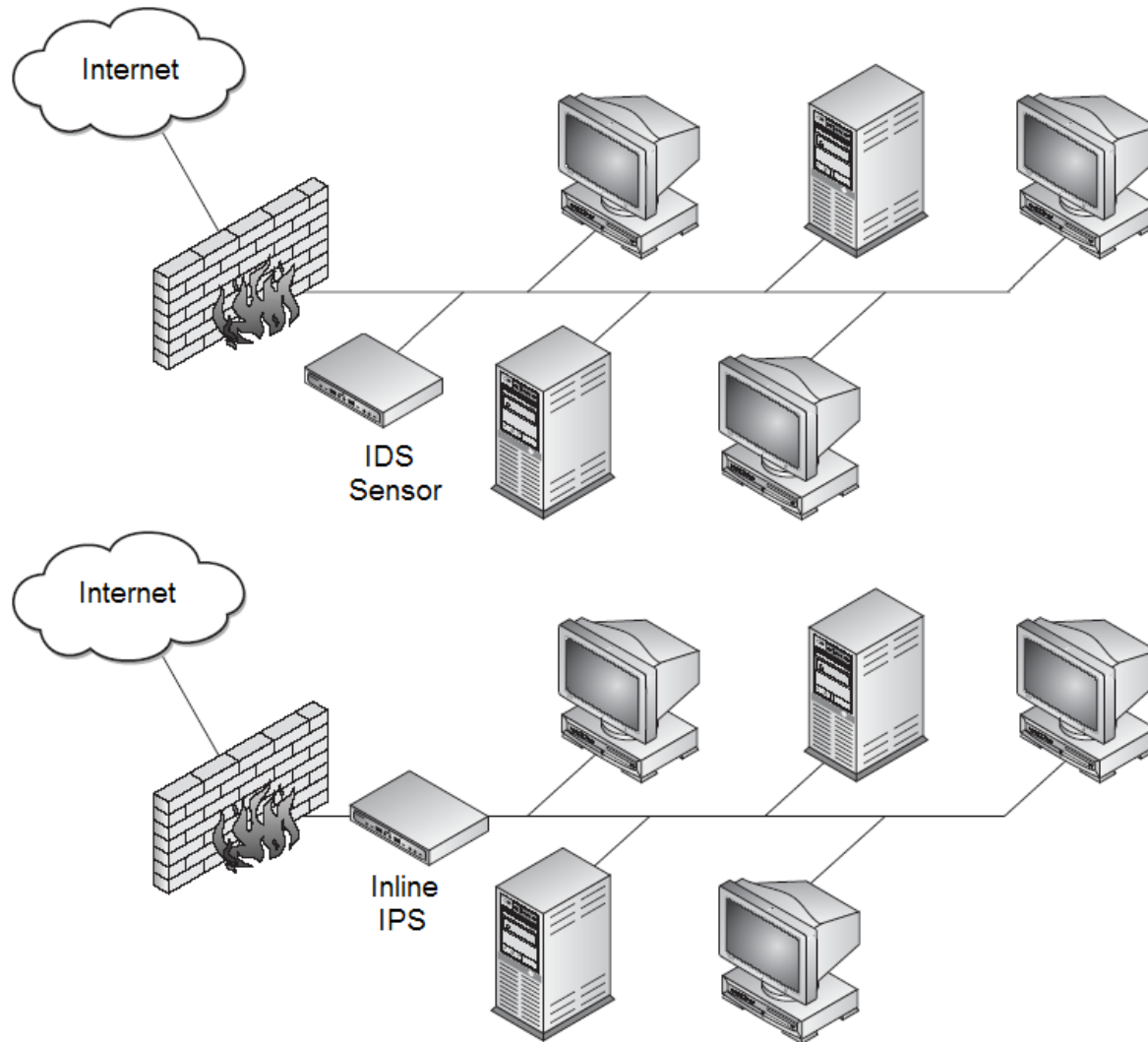
IDS bazat pe anomalii (cont.)

- **Avantaje:**
 - pot detecta tipuri noi de atacuri
- **Dezavantaje:**
 - număr relativ mare de alarme de tip *false positive*
 - configurația sistemelor se modifică în mod constant!
 - transmite alarme generice
 - personal specializat pentru investigarea cauzelor!

Răspunsul la atacuri

- **Răspunsuri pasive**
 - alarme și notificări
 - trape SNMP
- **Răspunsuri active**
 - resetare conexiune
 - modificare ACL din router / firewall

IDS vs. IPS



Caracteristici cheie pentru un IDS/IPS

- **Colectare de informații**
 - tipuri de senzori
 - volumul de trafic analizat
- **Capabilități de detecție / prevenție**
 - definire reguli de detecție, blacklists, whitelists
 - acuratețea detecției (numărul de falsuri pozitive / negative)
- **Modularitate**
 - plugin-uri pentru modificarea / extinderea funcționalităților
- **Jurnalizare**
 - locală (fișier de log)
 - centralizată (syslog)
- **Management**
 - separarea rolurilor
 - consolă de administrare

Limitările IDS/IPS

- Majoritatea IDS/IPS actuale folosesc ca mecanism de detecție semnăturile și anomaliile de protocol
- Efortul de administrare al unui IDS/IPS este destul de ridicat
 - tuning, investigare alarme, etc
- Eficiență scăzută în cazul atacurilor “low and slow”
 - Advanced Persistent Threats (APT)
- Tendința este de integrare a funcției de IDS/IPS în cadrul firewall-urilor

Produce IDS/IPS

- **Network-based:**
 - Snort
 - Suricata
 - Zeek (Bro)
 - Cisco Firepower
 - Palo Alto Networks IDS/IPS

- **Host-based:**
 - OSSEC
 - McAfee Intrusion Prevention System
 - Symantec Critical System Protection

